

Clase 213 — Anti-forense y sus contramedidas

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: *The Art of Memory Forensics* y literatura de anti-forensics ⌚ Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Conocer las técnicas que los atacantes usan para borrar sus huellas y engañar al analista —borrado seguro, timestomping, cifrado, ocultamiento, log tampering, esteganografía— y, sobre todo, aprender a **detectarlas y contrarrestarlas**. Al terminar sabrás reconocer cuándo alguien intentó destruir o falsear evidencia.

⚠ **Nota ética:** estas técnicas se estudian para defender y detectar. Prácticalas solo en tus propios sistemas de laboratorio. Usar anti-forense para obstruir una investigación real es ilegal.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Clasificar** las principales familias de técnicas anti-forense.
- 2. **Detectar** timestomping y manipulación de metadatos.
- 3. **Identificar** borrado y limpieza de logs.
- 4. **Reconocer** ocultamiento de datos y esteganografía.
- 5. **Aplicar** contramedidas y fuentes redundantes de evidencia.

Temas

#	Tema	Por qué importa
1	Familias de anti-forense	Mapa del terreno
2	Borrado seguro (wiping)	Destrucción de datos
3	Timestomping	Falsear la cronología
4	Limpieza de logs	Borrar el rastro
5	Cifrado y ocultamiento	Negar acceso al contenido
6	Esteganografía	Datos escondidos en otros datos
7	Living-off-the-land	No dejar binarios propios
8	Detección y redundancia	Cómo se contraatacan

Definiciones y características

- **Wiping:** sobrescritura para impedir recuperación. Característica: en SSD, TRIM ya complica la recuperación; en HDD, deja patrones detectables.
- **Timestomping:** alterar timestamps (p. ej. con `timestomp` o `SetFileTime`). Característica: crea incoherencias entre `$SI`, `$FN` y logs.
- **Log tampering:** borrar/editar logs (`wevtutil cl`, truncar `/var/log`). Característica: deja huecos y gaps de secuencia detectables.
- **Esteganografía:** ocultar datos dentro de imágenes, audio, etc. Característica: cambia estadísticas del portador.
- **Cifrado/ADS:** cifrar datos o esconderlos en *Alternate Data Streams* de NTFS. Característica: los ADS son invisibles en un `dir` normal.
- **LOLBins:** binarios legítimos del SO usados con fines maliciosos. Característica: no dejan un ejecutable ajeno que analizar.
- **Redundancia de evidencia:** cruzar fuentes independientes. Característica: la mejor contramedida contra la manipulación.

Herramientas y preparación

- **Detección:** MFTECmd (`$SI` vs `$FN`), EvtxECmd (gaps de secuencia), `streams / dir /r` (ADS), `stegdetect / zsteg` (esteganografía), `binwalk`.
- **Análisis de wiping:** inspección de patrones en espacio no asignado.
- **Entorno:** laboratorio propio. Genera tú las técnicas y luego detéctalas.

Laboratorio guiado

Todo sobre tus propios sistemas de laboratorio.

1. **Timestomping y su detección:** cambia el mtime de un archivo propio y detéctalo comparando `$SI` vs `$FN` en la MFT:

```
bash MFTECmd.exe -f "$MFT" --csv salida --csvf mft.csv
```

Busca registros donde los tiempos de `$SI` sean anteriores a los de `$FN` (imposible en uso normal).

2. **Alternate Data Streams:** crea y detecta un ADS en NTFS:

```
cmd echo secreto > archivo.txt:oculto.txt dir /r
```

3. **Limpieza de logs:** borra un log de eventos propio y detecta el hueco:

```
cmd wevtutil cl Application
```

El propio evento 1102 ("audit log cleared") delata la limpieza; búscalo. 4. **Esteganografía:** esconde un texto en una imagen propia y detéctalo:

```
bash zsteg imagen.png binwalk imagen.png
```

5. **Wiping:** sobrescribe un archivo y observa el espacio no asignado; discute por qué el patrón (o su ausencia) es una pista.

6. Documenta, para cada técnica, la **contramedida**: qué fuente redundante permitió detectarla.

Ejercicios

1. Detecta timestomping por incoherencia `$SI` / `$FN`.
2. Crea y encuentra un ADS en NTFS.
3. Identifica una limpieza de log por el evento 1102.
4. Detecta datos ocultos en una imagen con `zsteg/binwalk`.
5. Explica por qué el TRIM ayuda al atacante que quiere borrar.
6. Diseña una estrategia de redundancia de evidencia contra cada técnica.

Reto verificable

En un sistema de laboratorio propio, aplica tres técnicas anti-forense distintas (por ejemplo timestomping, limpieza de un log y un ADS) y luego, actuando como analista, détéctalas todas usando fuentes de evidencia independientes.

Criterio de aceptación: por cada una de las tres técnicas, presentas (a) cómo la aplicaste, (b) la evidencia que la delató y (c) la fuente redundante que usaste para detectarla pese a la manipulación.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Confías en un solo timestamp	Es manipulable. Cruza <code>\$SI</code> , <code>\$FN</code> , <code>\$UsnJrnl</code> y logs.
No ves el ADS	<code>dir</code> normal no lo muestra. Usa <code>dir /r</code> o <code>streams</code> .
Log "limpio" sin sospecha	Un log vacío o con gaps ya es sospechoso. Revisa el evento 1102.
Esteganografía indetectable	Prueba varias herramientas y análisis estadístico; compara con el portador original si existe.
Asumes que el wiping borró todo	Copias en shadow copies, journal, backups o RAM pueden sobrevivir.

Preguntas frecuentes

? ¿El anti-forense hace imposible la investigación? Casi nunca del todo. Deja sus propias huellas (incoherencias, huecos) y suele olvidar fuentes redundantes.

? ¿Cómo detecto timestomping? Comparando timestamps que deberían concordar entre fuentes independientes; las incoherencias delatan la manipulación.

? ¿Qué es un LOLBin? Un binario legítimo del sistema (PowerShell, certutil, rundll32...) usado con fines maliciosos para no dejar malware propio.

? ¿Puedo recuperar algo tras un wipe en SSD? Difícil por TRIM, pero busca en shadow copies, backups, journal, memoria y logs externos.

Referencias

- Ligh, Case, Levy, Walters — *The Art of Memory Forensics*, Wiley 2014.
- MITRE ATT&CK — Defense Evasion (TA0005): <https://attack.mitre.org/tactics/TA0005/>
- Eric Zimmerman's Tools: <https://ericzimmerman.github.io/>
- LOLBAS project: <https://lolbas-project.github.io/>

Siguiente clase

Clase 214 - Recuperacion de datos y file carving